

REPORT - SQL Injection Vulnerability

INTRODUCCIÓN

El informe describe un incidente de seguridad detectado durante la evaluación de una aplicación web vulnerable.

El objetivo de la práctica era analizar el comportamiento de una aplicación web ante ataques de inyección SQL y comprender como una mala validación de entradas de usuario puede comprometer la confidencialidad de la información almacenada en una base de datos.

Las pruebas se hicieron sobre la aplicación DVWA, así se identificó la vulnerabilidad que permitió acceder a información en la base de datos.

DESCRIPCIÓN DEL INCIDENTE

El incidente consiste en un ataque de inyección SQL mediante un campo de entrada de usuario dentro de la aplicación web. La aplicación no validaba correctamente los datos introducidos por el usuario, permitiendo que código SQL malicioso fuese interpretado por la base de datos de MariaDB. Y como consecuencia, se podía modificar la consulta SQL y obtener información completa de los usuarios almacenados en la base de datos.

PROCESO

El incidente se reprodujo siguiendo los siguientes pasos:

1. Instalación y configuración de la aplicación DVWA en un servidor Debian con Apache, PHP y MariaDB.
2. Acceso a la aplicación web mediante el navegador en la dirección:

<http://localhost/DVWA>

3. Inicio de sesión en la aplicación.
4. Configuración del nivel de seguridad en **LOW**, lo que desactiva los mecanismos de protección contra ataques.
5. Acceso al módulo **SQL Injection** dentro de la aplicación.
6. Introducción del siguiente valor en el campo de entrada:

`1'or'1'='1`

7. La aplicación ejecutó la consulta SQL modificada y mostró múltiples registros de usuarios extraídos de la base de datos.

Esto confirmó la existencia de la vulnerabilidad.



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

DVWA Security

PHP Info

About

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

IMPACTO DEL INCIDENTE

El impacto de esta vulnerabilidad es crítico, ya que permite:

- Acceso no autorizado a datos almacenados en la base de datos.
- Exposición de información sensible de usuarios.
- Posible robo de credenciales.
- Compromiso total de la aplicación web.
- Riesgo de ataques posteriores como escalada de privilegios.

En un entorno real, este tipo de vulnerabilidad podría provocar filtraciones de datos personales y daños reputacionales graves para la organización afectada.

RECOMENDACIONES

Para mitigar este tipo de vulnerabilidades se recomienda:

- Validar y sanitizar todas las entradas del usuario.
- Utilizar consultas preparadas (Prepared Statements) en lugar de concatenar variables en consultas SQL.
- Evitar el uso directo de cuentas privilegiadas de base de datos.
- Implementar niveles adecuados de seguridad en aplicaciones web.
- Monitorizar logs del servidor para detectar patrones de ataque.
- Aplicar principios de mínimo privilegio en el acceso a bases de datos.

CONCLUSIÓN

El ejercicio demostró cómo una incorrecta validación de entradas puede permitir la explotación de una aplicación web mediante un ataque de inyección SQL.

La prueba realizada dejó claro que el ataque puede manipular consultas SQL y acceder a información sensible sin necesidad de autenticación válida.

Este tipo de vulnerabilidad continúa siendo una de las más comunes en aplicaciones web, por lo que resulta fundamental aplicar buenas prácticas de desarrollo seguro y controles adecuados de validación de datos.